启核图策 NexcoreGraph Web 端部署指南

适用版本：2026-11-11

适用目录：`web/NexcoreGraph_web` + `harmonyosapp/NexcoreGraph_harmonyos/backend`

已验证环境：Windows、Node.js 24、Python 3.14、MySQL 8、Edge

1. 部署拓扑

浏览器

```
  |
  ├─ HTTPS / 静态资源 ──> Nginx / 静态托管
  |
  └─ /api/* ──────────────> Node.js 后端 :3000
                              |
                              ├─ MySQL 8
                              ├─ AI 模型网关
                              └─ SMTP 邮件服务
```

本项目有三种运行形态：

表 1-1

形态	用途	必需组件	当前状态
本地演示	开发、答辩、自动测试	Web 安全静态服务 + 可选后端	已实测
局域网评审	同一 WiFi 内手机/平板访问	Web + 后端 + MySQL	可部署，需防火墙放行
公网 HTTPS	在线演示加分项	域名 + HTTPS 反向代理 + 后端 + MySQL	需实际服务器与域名

2. 端口与组件

表 2-1

服务	默认端口	是否可以公网直接暴露
Web 静态服务	8080 / 8090	公网建议只经 Nginx 443
Node API	3000	否，只允许反向代理访问
MySQL	3307 / 3306	否，仅本机或私网
HTTPS	443	是

3. 环境要求

本地/局域网

- Windows 10/11，或 Linux/macOS。
- 现代 Chrome / Edge。
- Python 3.10+：启动 Web 安全静态服务。
- Node.js 18+，推荐 24：运行后端与测试。
- MySQL 8：后端持久化。

公网 Linux 服务器

- Ubuntu 22.04/24.04 或同类 Linux。
- Node.js 20/22/24。
- MySQL 8。
- Nginx 或 Caddy。
- Certbot 或云厂商免费 TLS 证书。

4. 代码目录

```
NexcoreGraph/

├─ web/NexcoreGraph_web/                    Web 用户端与管理员端

├─ harmonyosapp/NexcoreGraph_harmonyos/

│  └─ backend/                              Node API、MySQL、AI 网关、SMTP
```

```
├─ tools/serve_web.py                    安全静态服务器
├─ tools/verify_rescue_web.py            浏览器端到端验收
├─ deploy/nginx.nexcoregraph.conf.example
└─ deploy/nexcoregraph-backend.service.example
```

5. 数据库准备

创建专用数据库和账号，生产环境不要使用 root：

```
CREATE DATABASE tianshu CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;

CREATE USER 'nxg_app'@'127.0.0.1' IDENTIFIED BY '替换为强密码';

GRANT ALL PRIVILEGES ON tianshu.* TO 'nxg_app'@'127.0.0.1';

FLUSH PRIVILEGES;
```

后端启动时会执行自身的建表与补列逻辑。首次部署后先检查启动日志是否出现：

```
[nexcoregraph-backend] DB 就绪
```

6. 后端配置

进入后端目录：

```
cd harmonyosapp/NexcoreGraph_harmonyos/backend

npm ci
```

复制模板：

```
cp .env.example .env
```

模板：

```
PORT=3000


DB_HOST=127.0.0.1

DB_PORT=3307

DB_USER=nxg_app

DB_PASSWORD=替换为强密码
```

```
DB_NAME=tianshu


AGNES_API_KEY=替换为服务端密钥
AGNES_BASE_URL=https://api.agnes-ai.cn/v1
AGNES_MODEL=agnes-2.0-flash
AGNES_MODEL_ALT=agnes-3.0-flash
AI_TIMEOUT_MS=25000
AI_RPM=20


MAIL_HOST=smtp.163.com
MAIL_PORT=465
MAIL_USER=你的发件邮箱
MAIL_PASS=邮箱 SMTP 授权码
MAIL_FROM=你的发件邮箱


SMS_ENDPOINT=
SMS_API_KEY=
AUTH_SHOW_CODE=0
```

安全要求：

- `.env` 必须保持在服务器本地，不能放进 Web 根目录。
- `AUTH_SHOW_CODE` 生产环境必须为 `0`。
- AI Key 只配置在服务端。
- 邮件密码填写 SMTP 授权码，不是邮箱登录密码。
- 如密钥曾出现在截图、日志或公开仓库中，应立即轮换。

启动：

```
npm start
```

预期日志：

```
[nexcoregraph-backend] listening on http://0.0.0.0:3000
```

健康检查：

```
curl http://127.0.0.1:3000/api/health
```

预期包含：

```
{"ok":true,"service":"nexcoregraph-backend","mode":"lan-self-hosted"}
```

7. 本地 Web 启动

推荐方式

在仓库根目录运行：

```
python tools/serve_web.py --root web/NexcoreGraph_web --port 8080
```

浏览器打开：

- 用户端：`http://127.0.0.1:8080/`
- 管理员端：`http://127.0.0.1:8080/admin.html`
- 临期救援：`http://127.0.0.1:8080/index.html#/rescue`

也可以使用：

- Windows：`web/NexcoreGraph_web/start.bat`
- macOS/Linux：`bash web/NexcoreGraph_web/start.sh`

不要使用 `python -m http.server` 直接暴露工程目录。`serve_web.py` 会拒绝：

- `.env` 与 `.env.example`
- 任意点文件/点目录
- 目录列表
- 路径穿越

验收：

```
curl -I http://127.0.0.1:8080/.env
```

必须返回 404。

8. 局域网评审

8.1 启动后端

后端已监听 `0.0.0.0:3000`。

8.2 启动 Web

```
python tools/serve_web.py \

  --root web/NexcoreGraph_web \

  --port 8080 \

  --bind 0.0.0.0
```

8.3 防火墙

只放行评审需要的端口：

- `8080/tcp`：Web
- `3000/tcp`：API

Linux 示例：

```
sudo ufw allow 8080/tcp

sudo ufw allow 3000/tcp

sudo ufw status
```

Windows 示例：

```
New-NetFirewallRule -DisplayName "NexcoreGraph Web 8080" -Direction Inbound -Protocol
TCP -LocalPort 8080 -Action Allow

New-NetFirewallRule -DisplayName "NexcoreGraph API 3000" -Direction Inbound -Protocol
TCP -LocalPort 3000 -Action Allow
```

8.4 手机访问

查看后端启动日志中的局域网地址，例如：

```
http://10.51.102.251:3000
```

手机打开：

```
http://电脑局域网 IP:8080/
```

若校园网开启客户端隔离，设备即使在同一 WiFi 也无法互访。应改用手机热点，或在路由器后台关闭 AP Isolation。

9. 公网 HTTPS 部署

推荐使用同域名反向代理：

- `https://demo.example.com/` → Web 静态文件
- `https://demo.example.com/api/*` → `127.0.0.1:3000`

这样浏览器会优先探测同源 `/api/health`，不需要单独配置 CORS。

9.1 上传代码

```
sudo mkdir -p /srv/nexcoregraph

sudo chown -R $USER:$USER /srv/nexcoregraph

git clone <你的公开仓库地址> /srv/nexcoregraph

cd /srv/nexcoregraph

git checkout <评审稳定分支>
```

不要把 `.env`、真实 Key、数据库备份放进 Web 根目录。

9.2 安装后端

```
cd /srv/nexcoregraph/harmonyosapp/NexcoreGraph_harmonyos/backend

npm ci --omit=dev

cp .env.example .env

chmod 600 .env
```

按第 6 节填写生产配置。

9.3 systemd

创建专用运行用户并授权：

```
sudo useradd --system --home /srv/nexcoregraph --shell /usr/sbin/nologin nexcore ||
true

sudo chown -R nexcore:nexcore /srv/nexcoregraph
```

复制模板：

```
sudo cp /srv/nexcoregraph/deploy/nexcoregraph-backend.service.example \
  /etc/systemd/system/nexcoregraph-backend.service
```

检查并替换模板中的路径和用户：

```
sudoedit /etc/systemd/system/nexcoregraph-backend.service
sudo systemctl daemon-reload
sudo systemctl enable --now nexcoregraph-backend
sudo systemctl status nexcoregraph-backend
```

日志：

```
sudo journalctl -u nexcoregraph-backend -f
```

9.4 Nginx

复制模板：

```
sudo cp /srv/nexcoregraph/deploy/nginx.nexcoregraph.conf.example \
  /etc/nginx/sites-available/nexcoregraph
sudo ln -sf /etc/nginx/sites-available/nexcoregraph \
  /etc/nginx/sites-enabled/nexcoregraph
sudo nginx -t
sudo systemctl reload nginx
```

模板会：

- 将 `/api/*` 转发到 `127.0.0.1:3000`
- 直接托管 Web 静态文件
- 拒绝点文件
- 禁止目录列表
- 为 HTML 设置 `no-store`
- 为静态资源设置较长缓存
- 限制上传大小
- 增加安全响应头

9.5 TLS

Certbot 示例：

```
sudo apt install certbot python3-certbot-nginx

sudo certbot --nginx -d demo.example.com
```

证书续期检查：

```
sudo certbot renew --dry-run
```

如果使用云厂商证书，将证书路径替换到 Nginx 模板。

10. 评审账号

项目使用邮箱 + 真实邮件验证码，不提供固定公开验证码。

建议流程：

1. 配置 SMTP。
2. 使用评审专用邮箱登录一次。
3. 在家庭页面确认角色为管理员或成员。
4. 如系统提供密码设置，设置独立评审密码。
5. 只把测试账号交给组委会，不在公开 README 中写明文密码。
6. 评审结束后禁用或删除测试账号。

11. 部署后验收

11.1 健康检查

```
curl -fsS https://demo.example.com/api/health
```

11.2 安全页

```
curl -o /dev/null -s -w "%{http_code}\n" https://demo.example.com/.env

curl -o /dev/null -s -w "%{http_code}\n" https://demo.example.com/.env.example
```

两条都必须输出 `404`。

11.3 浏览器自动化

在仓库根目录：

```
python tools/verify_rescue_web.py \

  --url "https://demo.example.com/index.html#/rescue"
```

预期关键字段：

```
{
  "navigation": true,
  "filter": true,
  "execute": true,
  "undoRestoresStock": true,
  "inventoryStep": true,
  "manualAdd": true,
  "search": true,
  "consoleErrors": [],
  "tabletOverflowX": 0,
  "mobileOverflowX": 0
}
```

11.4 实际人工路径

7. 登录。
8. 工作台看到“今晚先救哪几样”。
9. 进入临期救援并切换筛选。
10. 手动添加一件库存。
11. 增加数量，再执行方案。
12. 撤销方案并核对数量。
13. 全局搜索刚添加的物品。
14. 打开管理员端。
15. 检查移动端和横屏。

12. 日志、备份与监控

日志

- 后端：`journalctl -u nexcoregraph-backend`
- Nginx：`/var/log/nginx/access.log`、`/var/log/nginx/error.log`

日志中不得出现完整 API Key、验证码、Token 或用户图片内容。

MySQL 备份

```
mysqldump --single-transaction --routines --triggers \
  -h 127.0.0.1 -P 3307 -u nxg_backup -p tianshu \
  | gzip > /var/backups/nexcoregraph-$(date +%F-%H%M).sql.gz
```

建议：

- 每日执行。
- 保留 7–14 天。
- 定期在独立数据库恢复一次。
- 备份文件权限设为仅服务账号可读。

监控

至少监控：

- `/api/health` HTTP 状态。
- Node 进程是否存活。
- MySQL 磁盘与连接数。
- AI 上游 429/500 比例。
- 磁盘剩余空间。

13. 安全清单

- [ ] 仓库为 Public，或已提供评审访问权限。
- [ ] `.env` 不在 Git、Web 根目录或提交包中。
- [ ] `AUTH_SHOW_CODE=0`。
- [ ] MySQL 不使用 root。
- [ ] 3000/3307 不直接暴露公网。
- [ ] Nginx 拒绝点文件、目录列表和路径穿越。
- [ ] HTTPS 证书有效并自动续期。
- [ ] AI Key 只在服务端。
- [ ] 邮件授权码只在服务端。
- [ ] 日志不打印完整密钥、验证码或 Token。
- [ ] 评审账号与权限已验证。
- [ ] 数据库备份与恢复演练已完成。

14. 常见问题

页面提示“未找到本机后端”

检查：

```
curl http://127.0.0.1:3000/api/health
```

公网检查：

```
curl https://demo.example.com/api/health
```

浏览器提示摄像头不可用

摄像头需要 `localhost` 或 HTTPS。公网 HTTP 页面不能稳定使用摄像头。

验证码发送失败

- 检查 SMTP 主机、端口和授权码。
- 检查发件邮箱是否开启 SMTP 服务。
- 检查服务器是否允许出站 465/587。
- 检查发件频率限制。

AI 返回 429/500

- 检查上游账户额度和模型状态。
- 后备模型是否配置。
- Web 会降级到本地 GraphRAG，不应伪造模型成功结果。

`.env` 返回 200

说明仍在使用不安全的 `python -m http.server`。立即停止服务，改用：

```
python tools/serve_web.py --root web/NexcoreGraph_web --port 8080
```

如该目录曾公网暴露，立刻轮换其中的全部密钥。

15. 回滚

16. 保留上一版 Git 提交哈希与数据库备份。
17. 前端回滚：切换上一版静态目录或 `git checkout <稳定提交>` 后重新部署。
18. 后端回滚：切换稳定提交、`npm ci`、重启 systemd。
19. 数据库回滚前先停止写流量并再次备份。
20. 回滚后重新执行健康检查与浏览器验收。

16. 当前验证结论

本轮已实测：

- Web 安全静态服务与后端健康接口可启动。
- `.env`、路径穿越和目录列表返回 404。
- Web 求解器单元测试 8/8 通过。
- 浏览器真实操作流程连续 3 轮通过：救援、执行、撤销、数量变更、手动新增、搜索。
- 桌面、平板、手机无横向溢出，控制台异常 0。
- 微信小程序类型检查、19 项测试和构建通过。
- HarmonyOS 后端测试 10/10 通过，HAP 构建成功但尚未签名。

未完成或需外部条件：

- 仓库匿名访问仍需确认 Public/评审权限。
- 公网域名、HTTPS 和在线演示地址尚未部署。
- 微信开发者工具页面级自动化连接曾关闭，不能替代真机验收。
- AI 上游在部分复核时段返回 500/429，降级路径正常。